Microsoft 365

監視からインサイトへ: シャドウ AI のリスクを管理する



目次

イントロダクション..... 03

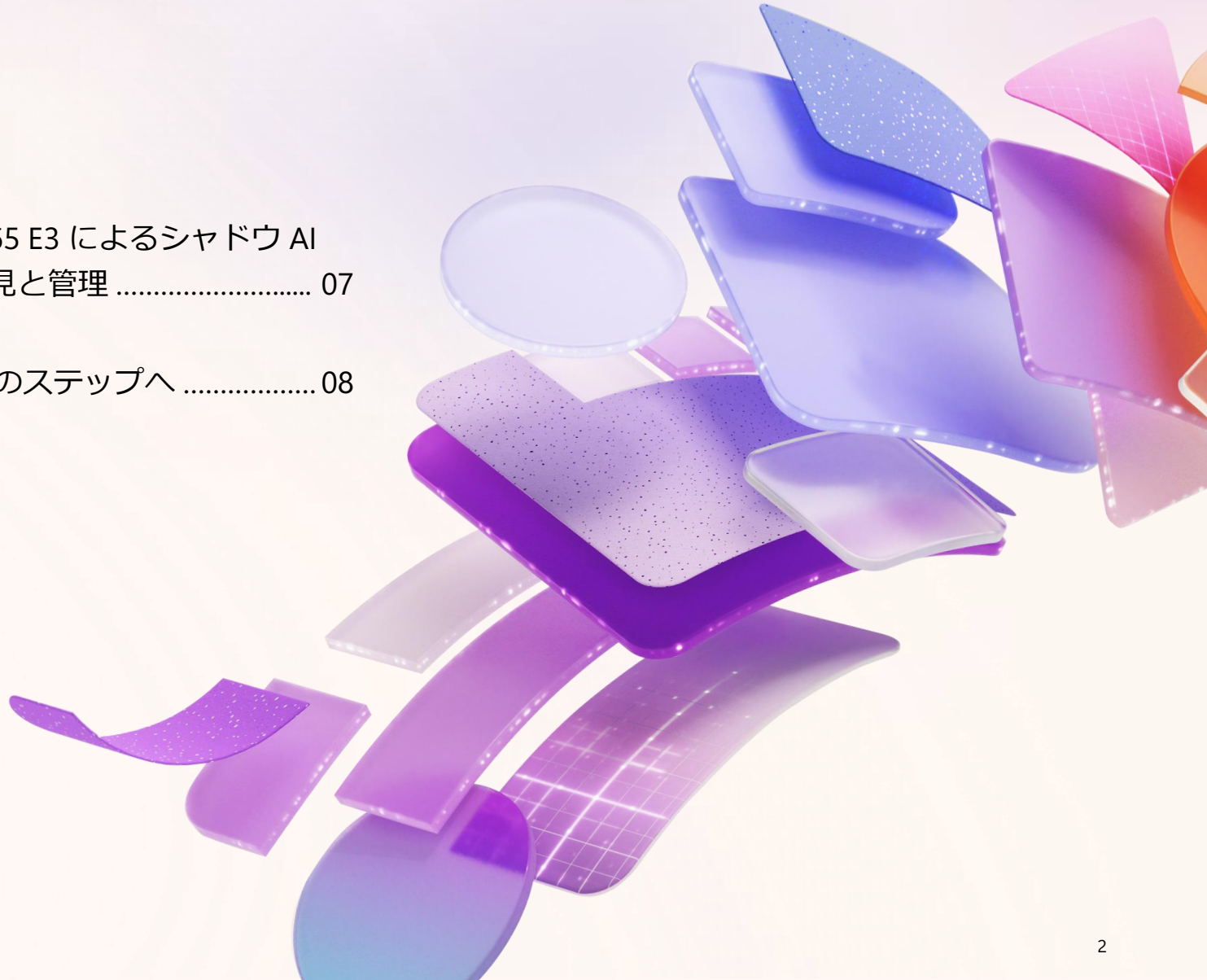
エージェント AI とは何か、そして、
なぜ可視性が重要なのか..... 04

職場におけるシャドウ AI:
シナリオ例と潜在的なリスク..... 05

シャドウ AI のリスクを管理する
ための 5 つの方法 06

Microsoft 365 E3 によるシャドウ AI
リスクの発見と管理 07

AI 導入の次のステップへ 08



イントロダクション

最近発表されたワーク トレンド インデックス レポートによると、31 か国のナレッジ ワーカー (社員およびリーダー) の 80 %以上が、業務を遂行するための時間やエネルギーが不足していると感じていると回答しました。さらに、調査対象となったビジネス リーダーの 50% 以上が、目標達成のためには生産性の向上が必要だと報告しています[1]。「2024 マイクロソフトのワーク トレンド インデックス レポート」によると、多くの社員がこのギャップを埋めるために生成 AI ツールの活用を始めており、正式な IT 承認を待たずに利用を開始しています。

IT 部門の管理外でツールが運用される場合、組織にセキュリティやコンプライアンスのリスクが生じる可能性があります。そして、IT 部門の承認なしに AI ツールを使用する「シャドウ AI」は、今日の職場における最新のシャドウ IT の形態として現れています。

AI の採用が加速するにつれて、ビジネス リーダーは一歩先を行き、AI ツールがもたらす可能性のあるリスクを軽減するよう取り組んでいます。最近の iSMG の調査によると、調査対象のビジネス リーダーの 70% 以上が、データのプライバシーとセキュリティの確保が、生成 AI を既存の IT インフラに統合する際の主要な課題であると報告しています[2]。さらに、調査対象となった CIO および CTO の 90% 以上が、生成 AI によって、既に自組織でのサイバーセキュリティ投資が促進された、または今後促進されると報告しました[3]。

本 e-Book では、シャドウ AI が利用されている一般的なシナリオについて調べて、組織に潜むリスクを理解し、それらのリスクを管理するための 5 つの方法を確認し、Microsoft 365 E3 がどのように役立つかをご覧いただけます。



[1]「2025 年ワーク トレンド インデックス年次レポート」、Microsoft, Inc.、2025 年 4 月。マイクロソフトは、2025 年 2 月 6 日から 2025 年 3 月 24 日の間に 31 か国にわたる 31,000 人のフルタイム就業者または自営業ナレッジ ワーカーから得た調査データ、LinkedIn の労働市場の傾向、および Microsoft 365 の生産性シグナルの数兆件を分析しました。

[2]「iSMG Second Annual Generative AI Study: Business Rewards vs. Security Risks」、第 3 四半期の調査回答に基づく 6 地域 (北米、欧州、アジア、南アメリカ、オーストラリア、アフリカ) の 360 人以上のビジネスおよびサイバーセキュリティ専門家による

[3]「The AI Security Balancing Act: From Risk to Innovation」、NTT DATA、2025 年 6月、NTT DATA が実施した調査データに基づく (34 か国の 2,300 人以上のシニア生成 AI 意思決定者のうち、1,500 人は経営幹部レベルのリーダー)。

エージェント AI とは何か、そして、なぜ可視性が重要なのか?

シャドウ AI とは、社員が IT 部門の明確な承認や監督を受けずに、公式のセキュリティおよびコンプライアンスの枠組みの管理が及ばない範囲で、AI ツールやアプリケーションを利用することを指します。社員は生産性を高め、増大する業務の要求に対応するために、タスクの効率化や共同作業、新しいコンテンツの生成を目的として、これらの未承認のソリューションに頼ることがありますが、しばしばその潜在的なリスクに気付かずに利用しています。シャドウ AI は IT 部門からは見えないため、どのアプリケーションが使用されているか、どのアプリケーションが最大のリスクをもたらすかを組織が判断することは困難です。



シャドウ AI の可視性が重要な理由

IT 部門がアプリケーションやサービスを把握していない場合、保護したりサポートしたりすることはできません。この可視性のギャップがあることで、機密データの漏洩、規制違反、独自情報の管理喪失に関連する潜在的な脅威を正確に識別、管理、緩和することが困難になります。IT 部門および経営層は、自社で利用されているシャドウ AI の状況を把握し、AI 利用に伴う新たなリスクに対処し、適切な管理策のもとで許可すべきツールを決定する必要があります。組織にとってのチャンスは、シャドウ AI をリスクから安全に業務を革新する機会へと変えることです。これを実現するためには、より良いバランスが必要です。社員が管理とセキュアなフレームワーク内で有用な AI ツールを活用し、潜在的なリスクを軽減できるようにすることが重要です。

インサイト

見えないものを保護することはできません。IT 部門が使用されているアプリケーションやサービスを把握していなければ、それを保護することはできません。これがシャドウ AI の問題の核心であり、新しいアプローチが必要な理由を浮き彫りにしています。社員がこれらの AI ツールを目標達成に不可欠だと感じている場合、外部のツールをすべて禁止するだけでは現実的ではありません。その代わりに、組織はシャドウ AI の利用状況を可視化し、社員が何を使っているかを把握した上で、適切な管理を行い、組織のニーズを満たすセキュアで承認された代替手段を提供する必要があります。要するに、課題は AI でチームを強化しセキュリティを損なうことなく実現することです。

職場におけるシャドウ AI: シナリオ例と潜在的なリスク

シャドウ AI は、生産性と影響力を高めたり、新しいテクノロジを試したりしたいと考えている社員から生じます。以下は、未承認の AI ツールがどのように使用され、どのような潜在的なリスクをもたらすかを示す架空の事例です。

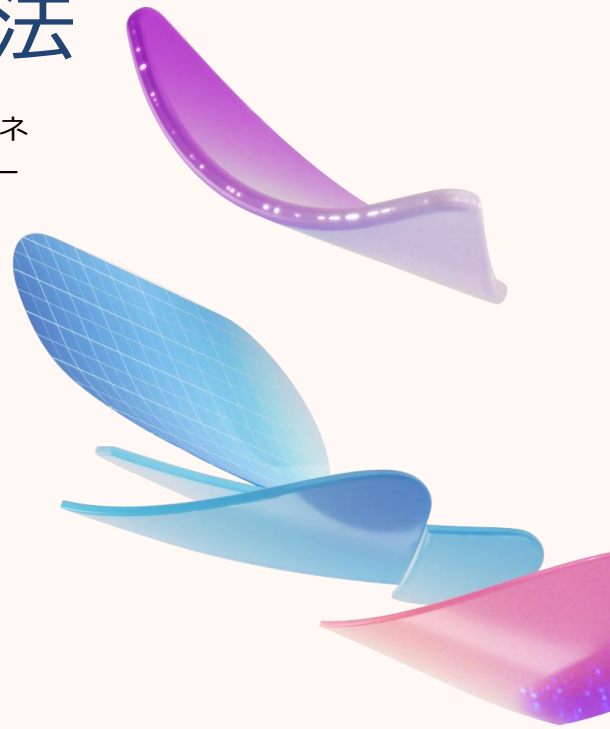
役割	シナリオの例	未承認ツールによる潜在的リスク
マーケティング	企業のブランド データを使用して、生成 AI コンテンツ ツールでマーケティング用のコピーやデザインを作成する。	機密性の高いブランドや製品情報の漏洩、外部 AI サービスによる会社のクリエイティブ資産の保管や利用方法を管理できなくなるリスク。
財務	企業の財務情報を AI 駆動型分析またはビジュアル化サービスにアップロードして、インサイトをすぐに得る。	機密性の高い財務データ (予算、予測など) が第三者に漏洩する可能性 - 顧客や社員のデータが適切な保護措置なしに含まれている場合、コンプライアンス違反 (例: GDPR) のリスクが生じる。
カスタマー サポート	クライアント データやサポート チャットのトランスクリプトを AI ツールに入力し、回答の作成やケースの要約に利用する。	プライバシーおよびデータ処理規則の違反 - 機密性の高い顧客情報が社外のシステムに保存される可能性があり、AI プロバイダーによるデータ保持や適切な削除について保証がない。
フロントライン - 小売	店舗マネージャーがスマートフォンで AI スケジューリング アプリを利用して社員のシフト表を最適化。	会社の社員データ (社員名、スケジュール) が未承認のアプリにアップロードされ、プライバシーの問題が発生するリスクがある。AI の提案が労働規制と合致しない場合、スケジュールの競合やポリシー違反が発生する可能性がある。
フロントライン - 医療	看護師や医師が、患者の診療記録の作成や医療に関する質問への回答のために AI チャットボットを利用する。	患者の医療情報 (PHI) が何の保護措置もなく外部サービスに漏洩し、コンプライアンスおよび機密性の要件に違反する可能性がある。AI の医療アドバイスも検証されていない可能性があり、安全上のリスクをもたらす。

上記のいずれの場合も、個々の社員は善意を持ち、生産性の向上を求めていましたが、結果として組織がリスクを継承する可能性があります。

会社情報が非公認のプラットフォームに分散し、データ ガバナンスの課題が生じます。未審査のアプリは、マルウェアやセキュリティの脆弱性を引き起こし、IT 管理外で攻撃面を拡大する可能性があります。コンプライアンス上の問題が生じる可能性もあります。IT サポートの観点から言えば、シャドウ AI ツールに問題が発生した場合、ヘルプ デスクは内容を把握できず、管理もできないため、エンド ユーザーを支援できない可能性があります。

シャドウ AI のリスクを管理するための 5 つの方法

適切な戦略とツールを用いることで、シャドウ AI を潜在的な脅威からセキュアなイノベーション文化を育む機会へと変えることができます。ビジネスを保護するために必要な監視を維持しながら、AI 生産性ツールでチームを強化します。これは、「絶対にノー」と言うのではなく、「適切なガードレールがあればイエス」と言うことです。以下の 5 つのヒントは、組織におけるシャドウ AI の管理と制御に役立つよう設計されています。



01 シャドウ AI のフットプリントを特定し、リスクを評価して優先順位を付ける

見えないものを保護することはできません。アクティビティ ログを活用して、組織で使用されているアプリケーションを可視化しましょう。使用されているアプリがわかれば、機密データを処理するための適切なツールを特定できると同時に、セキュリティおよびコンプライアンス ポリシーに準拠していないツールにも気付くようになります。これらのインサイトに基づき、どのアプリケーションを許可、監視、制限するかについて、潜在的なリスクを軽減するために十分な情報を得たうえで決定を下すことができます。

02 セキュリティとコンプライアンスのポリシーで成果をすばやく実現する

シャドウ AI の利用による潜在的なリスクをより効果的に軽減するため、ポリシーの修正を有効化または適用できます。条件付きアクセス ポリシーを使用して高リスクなアプリケーションの利用を制限し、データ損失防止ポリシーを用いて機密情報の過剰共有やデータ漏洩を防止し、すべてのユーザーに基本的な多要素認証とデバイス コンプライアンスを義務付けることができます。これらの手順により、使用されている AI アプリケーションを完全に把握していなくても、最も明白なリスクをすばやく軽減できます。

03 シャドウ AI の潜在的なリスクについて社員に周知、啓発する

多くの場合、社員は未承認 AI ツールの利用が組織にもたらすリスクに気づいていません。適切なデータ損失防止の警告、会社のポリシーのリマインダー、簡単なトレーニングを活用し、強制的な措置を取らずに、シャドウ AI のリスクを頻繁に伝え、ユーザーをより安全な運用へと促します。

04 承認された AI ツールを提供してリスクをさらに軽減する

可能であれば、社員に未承認の AI ツールの代替として承認済みの AI ツールを提供してください。シャドウ AI を削減する優れた方法は、組織内で最も一般的な使用用途を承認済みソリューションで満たすことです。これにより、IT 部門は可視性と制御を維持しつつ、発生した問題に対してユーザー サポートを提供できます。

05 継続的なガバナンスを確立する

IT ガバナンスの運用に確認手順を組み込み、アクティビティ ログやレポートを定期的に確認し、新しい AI サービスの登場に合わせてポリシーを更新し、進捗状況 (未承認アプリの利用減少や防止されたインシデントなど) を経営陣に報告しましょう。これにより、状況が変化する中で、現在および将来の潜在的なリスクを軽減するのに役立ちます。

上記の手順を実行することで、イノベーションとセキュリティの両立が可能になります。

社員は職場で承認済み AI ソリューションを利用でき、IT 部門はそれらのツールの管理と統制およびコンプライアンスを確保します。

Microsoft 365 E3 によるシャドウ AI リスクの発見と管理

Microsoft 365 E3 は、イノベーションを阻害することなく、シャドウ IT を検出して、潜在的なリスクを評価し、セキュリティとコンプライアンスのポリシーを実装する機能を組織に提供します。生産性、セキュリティ、管理機能を統合したこのスイートにより、シャドウ AI の課題に直接対処できます。



Microsoft 365 E3 ソリューション	シャドウ AI の潜在的なリスク管理を支援する方法
Cloud App Discovery	**未承認のアプリケーションを検出して対処する。**Cloud App Discovery を使用すると、アクティビティ ログをアップロードし、スナップショット レポートを作成することで、31,000 以上のクラウドアプリ (400 以上の生成 AI アプリを含む) の利用状況を把握できます。組織内で何が、誰によって、どのくらいの頻度で使用されているかを確認できます。この情報により、どのアプリの使用を許可するか、または制限するかについて十分な情報を得たうえで決定を下すことができます。
Microsoft Purview データ損失防止 (DLP)	**機密データの漏洩を軽減する。**Microsoft Purview DLP では、機密情報を検出し、Microsoft 365 のメールやファイルの共有をブロックまたは制限するポリシーを定義して適用できます。たとえば、ユーザーによるメールやファイルの共有での機密情報のやりとりを監視、監査、阻止し、ユーザーに警告するルールを設定できます。
Microsoft Entra ID P1	**クラウド アプリへのアクセスを管理する。**Microsoft Entra ID P1 を使用すると、条件付きアクセス ポリシーによって、誰がどのアプリケーションにどのような条件でアクセスできるかを制御できます。たとえば、多要素認証を必須にしたり、リスクが高いと判断したアプリへの企業アカウントでのログインを制限することもできます。Microsoft Entra ID P1 は、認可された条件下で、準拠デバイスを使用する適切なユーザーがクラウド リソースにアクセスできるようにし、承認されていないアプリへのアクセスを制限します。
Microsoft Intune P1	**デバイスおよびアプリの利用ポリシーを適用する。**Microsoft Intune P1 は、管理されコンプライアンスに準拠したデバイスを業務に使用できるようにし、それらのデバイスを管理するためのツールを提供します。たとえば、企業 PC への未承認ソフトウェアのインストールを禁止したり、特定の Web サイトやサービスへのアクセスを制限する構成をプッシュしたりできます。
Microsoft Defender for Endpoint P1	**未承認の URL へのトラフィックを制限する。**Microsoft Defender for Endpoint P1 は、マネージド デバイスから未承認の URL へのトラフィックをブロックすることで、危険と見なされるサイトからのリスクを軽減できます。たとえば、社員が会社のラップトップで既知の危険な AI サイトにアクセスしようとすると、そのサイトへのアクセスがブロックされます。





AI 導入の次のステップへ→

すべては、認識、適切なツール、積極的な計画から始まります。Microsoft 365 E3 は、組織が AI ソリューション向けの堅牢なセキュリティ基盤とガバナンス フレームワークを確立できるようにするツールを提供します。非公認ツールの可視化、機密データを保護するためのポリシーの有効化、そしてユーザー アクセスとデバイス セキュリティの両方の管理が可能です。事後対応的なスタンス (シャドウ AI が現れた後に発見、遮断する) から、AI の利用をセキュアに管理されたチャネルへ導く、よりプロアクティブなアプローチへ転換しましょう。また、AI セキュリティ評価を実施し、AI のセキュリティ態勢の向上方法を習得しましょう。エンタープライズ向け Microsoft 365 に含まれる機能について詳しくは、こちらをご覧ください。